

27/02/2025

Documentation utilisateurs et administrateurs

Walid RHOUMA



Sommaire

1. <u>Introduction</u>	(Page 2)
1.1 Objectif du document	(Page 2)
1.2 Contexte des modifications	(Page 2)
 2. <u>Evolution de l'architecture</u>	(Page 2 à 5)
 3. <u>Procédures</u>	(Page 5 à 9)
3.1 Procédure utilisateurs	(Page 5 à 7)
3.2 Procédure administrateurs	(Page 7 à 9)
 4. <u>Bonnes pratiques</u>	(Page 9)
 5. <u>Conclusion</u>	(Page 10)

1. Introduction :

1.1 Objectif du document :

Ce document a pour objectif de présenter les bonnes pratiques de sécurité à appliquer par les utilisateurs et les administrateurs, ainsi que les modifications effectuées sur l'infrastructure réseau afin d'améliorer la protection des systèmes et des données. Il détaille également l'impact de ces changements sur l'usage quotidien des services et fournit des procédures adaptées pour garantir une transition fluide.

En s'appuyant sur les recommandations de l'ANSSI, cette documentation vise à renforcer la cybersécurité tout en maintenant la continuité des opérations.

1.2 Contexte des modifications :

Dans un contexte de menaces croissantes sur les systèmes d'information, il est impératif de renforcer la sécurité du réseau afin de protéger les ressources sensibles et d'assurer la conformité aux bonnes pratiques en matière de cybersécurité.

Plusieurs mesures ont été mises en place, notamment :

- Une gestion plus stricte des accès aux services critiques,
- L'intégration d'un VPN sécurisé pour les connexions à distance,
- Une supervision accrue des activités réseau pour détecter et prévenir les incidents de sécurité,
- Une segmentation renforcée du réseau afin de limiter la propagation d'attaques potentielles.

Ces modifications impliquent des changements dans les habitudes des utilisateurs et des administrateurs. Ce document vise donc à accompagner ces évolutions en fournissant des recommandations et des procédures adaptées.

2. Evolution de l'architecture :

Dans le cadre de l'amélioration de la sécurité du réseau, plusieurs modifications ont été mises en place, visant à renforcer la protection des données et à assurer un contrôle accru des accès. Ces modifications sont directement liées aux recommandations de l'ANSSI et ont un impact significatif sur la sécurité du Système d'Information (SI).

❖ Segmentation du Réseau en VLAN

La mise en place de VLAN permet de segmenter le réseau en différentes zones de confiance, chacune ayant des politiques de sécurité spécifiques. Cette segmentation réduit l'impact potentiel en cas de compromission d'une zone et permet un contrôle plus strict des flux de données.

- **Impact :** Isolation des ressources sensibles, gestion fine des accès.
- **Recommandation ANSSI :** R5, R16, R19.

❖ Mise en place des ACL pour le trafic inter-VLAN

Pour renforcer la sécurité de cette segmentation, des listes de contrôle d'accès (ACL) sont configurées afin de restreindre les flux entre VLANs. Seules les communications strictement nécessaires sont autorisées, minimisant ainsi les risques de propagation d'une attaque et garantissant que chaque zone du réseau reste isolée selon le principe du moindre privilège.

- **Impact** : Isolation des ressources sensibles, gestion fine des accès.
- **Recommandation ANSSI** : R5, R16, R19.

❖ Création d'une DMZ

L'hébergement des services exposés à Internet (serveur web, messagerie, ...) dans une zone démilitarisée (DMZ) permettra d'isoler ces services du réseau interne. En cas de compromission d'un serveur dans la DMZ, l'attaquant ne pourra pas directement atteindre les ressources critiques de l'entreprise, limitant ainsi l'impact d'une intrusion.

- **Impact** : Réduction de la surface d'attaque du réseau interne ; Renforcement du contrôle des flux entrants et sortants.
- **Recommandation ANSSI** : R5, R16, R20.

❖ Utilisation de Protocoles Sécurisés (HTTPS au lieu de HTTP)

Le passage de HTTP à HTTPS pour les communications garantit le chiffrement des données, protégeant ainsi la confidentialité et l'intégrité des informations échangées. Ce protocole sécurisé empêche l'interception des données par des attaquants lors des transmissions réseau.

- **Impact** : Protection des échanges contre les attaques de type "man-in-the-middle".
- **Recommandation ANSSI** : R24, R21, R24-.

❖ Authentification par Certificat

L'authentification par certificat numérique sécurise l'accès au réseau en vérifiant utilisateurs et équipements autorisés. Les certificats auto-signés ou générés en interne via OpenSSL offrent une alternative économique aux solutions commerciales.

Ils protègent les connexions VPN, applications critiques et échanges HTTPS/TLS. Chaque connexion est validée avant l'accès.

Cette solution renforce la sécurité en éliminant les mots de passe faibles. Elle est indépendante et sans coût externe. Le chiffrement garantit confidentialité et intégrité des données.

L'accès VPN, les serveurs critiques et les interfaces d'administration nécessitent un certificat valide pour une authentification sécurisée.

- **Impact** : Amélioration de la gestion des identités et réduction des risques de compromission.
- **Recommandation ANSSI** : R16, R19, R21, R24.

❖ Pare-feu (Stormshield SN510 12 ports)

L'installation d'un pare-feu performant permettra de filtrer les flux entrants et sortants, assurant une protection contre les attaques extérieures. De plus, l'intégration de technologies avancées comme VPN, Proxy et IPS/IDS renforcera la défense périmétrique et interne, en limitant les risques d'intrusion et en garantissant la sécurité des communications.

VPN (Virtual Private Network) :

Le VPN garantit des connexions sécurisées pour les utilisateurs distants. Il assure la confidentialité des échanges grâce au chiffrement, une authentification stricte pour restreindre l'accès aux seuls utilisateurs autorisés, et un accès sécurisé aux ressources internes, y compris en télétravail ou en mobilité.

Proxy :

L'intégration d'un proxy au pare-feu renforce la sécurité et optimise le réseau en filtrant les accès web, bloquant les contenus malveillants ou inappropriés. Il améliore également les performances grâce à la mise en cache des contenus fréquents et permet l'inspection des flux HTTPS pour détecter d'éventuelles menaces dissimulées.

IPS/IDS (Intrusion Prevention System / Intrusion Detection System) :

Les systèmes IDS et IPS analysent le trafic réseau pour détecter et stopper les menaces en temps réel. L'IDS identifie les activités suspectes (scans de ports, tentatives d'exploitation), tandis que l'IPS bloque automatiquement les attaques avant qu'elles n'atteignent les systèmes cibles.

- **Impact** : Protection renforcée contre les attaques extérieures et les intrusions ; Contrôle strict des accès aux ressources internes ; Sécurisation des communications.
- **Recommandation ANSSI** : R16, R19, R21, R24.

❖ Poste d'Administration Dédié (PC Dell Optiplex 7020)

L'usage d'un poste d'administration dédié permet de séparer les activités d'administration du reste du réseau, réduisant ainsi le risque de compromission des outils d'administration. Ce poste est configuré pour ne permettre que l'accès aux ressources strictement nécessaires.

- **Impact** : Isolation des tâches d'administration, réduction du risque de compromission.
- **Recommandation ANSSI** : R9, R15, R16.

❖ Serveur de Virtualisation (HPE ProLiant DL20 Gen11)

La virtualisation des services sur un serveur dédié permet une meilleure gestion des ressources, tout en optimisant la sécurité par l'isolation des différentes VM. Ce serveur héberge plusieurs services sécurisés sous forme de machines virtuelles :

- Un serveur Active Directory, DNS, DHCP, ainsi qu'un outil de gestion des mises à jour WSUS. Ce dernier permet aux administrateurs de centraliser et de contrôler le déploiement des mises à jour de sécurité, des correctifs et des améliorations logicielles sur l'ensemble des machines du réseau.

- **Impact** : Contrôle et centralisation des mises à jour ; Optimisation de la bande passante ; Sécurisation des systèmes ; Automatisation et reporting
- **Recommandation ANSSI** : R22, R47.

- Un serveur de logs Rsyslog qui permet de collecter, stocker, centraliser et analyser les événements générés par les équipements et services du réseau. Cette solution facilite la surveillance en temps réel, l'identification des incidents de sécurité et la mise en conformité avec les bonnes pratiques de gestion des journaux.

- **Impact** Amélioration de la visibilité sur les événements réseau ; détection proactive des incidents de sécurité ; optimisation de la gestion des logs.
- **Recommandation ANSSI** : R11, R46, R47

- Un serveur de sauvegarde Rsync qui assure des sauvegardes sécurisées et optimisées en ne transférant que les données modifiées. Cela réduit la bande passante et le temps de sauvegarde tout en garantissant une restauration rapide en cas d'incident. L'automatisation et l'utilisation d'un serveur de stockage dédié renforcent la protection contre les pertes de données et les cyberattaques.

- **Impact** : Réduction des risques de perte de données et des interruptions de service ; amélioration de la résilience face aux cyberattaques ; optimisation des processus de sauvegarde.
- **Recommandation ANSSI** : R45.

❖ **Serveur de Stockage Dédié (HPE ProLiant ML30 Gen11)**

Le stockage dédié garantit la sécurité et la redondance des données critiques, avec des mécanismes de sauvegarde et de restauration en place pour assurer la continuité du service en cas de sinistre.

- **Impact** : Sécurisation des données et des sauvegardes.
- **Recommandation ANSSI** : R45, R46.

Le serveur de sauvegarde Rsync et le serveur de stockage dédié collaborent pour offrir une solution de sauvegarde complète. La VM Rsync transfère les données vers le serveur dédié, qui devient le principal lieu de stockage sécurisé et centralisé des sauvegardes.

Ces modifications apportent des améliorations significatives en matière de sécurité, en assurant une meilleure gestion des risques, une isolation des ressources sensibles, et un chiffrement des flux de données. Elles s'alignent directement avec les recommandations de l'ANSSI, contribuant ainsi à sécuriser l'ensemble du réseau et des systèmes d'information.

3. Procédures

3.1 Procédure utilisateurs :

Les modifications apportées au réseau auront un impact direct sur la manière d'accéder aux services internes et externes. Ces changements visent à renforcer la sécurité et à garantir que vos activités se déroulent de manière sécurisée tout en maintenant la continuité de l'accès aux ressources nécessaires à votre travail.

❖ **Sécurité des mots de passe**

Un mot de passe sécurisé est la première barrière de protection contre les intrusions. Les règles suivantes doivent être respectées :

- Utiliser un mot de passe d'au moins 12 caractères, combinant majuscules, minuscules, chiffres et caractères spéciaux.
- Ne jamais utiliser le même mot de passe pour plusieurs services.
- Modifier son mot de passe tous les 90 jours et en cas de suspicion de compromission.

❖ Comptes utilisateurs

Tous les utilisateurs doivent utiliser des comptes personnels pour accéder aux services internes. L'utilisation de comptes partagés ou génériques est désormais interdite. Ces comptes sont associés à des droits spécifiques qui déterminent les ressources accessibles.

- Vous devrez utiliser vos identifiants personnels pour vous connecter à tous les services.
- Il est essentiel de garder vos identifiants et mots de passe confidentiels. Si vous oubliez votre mot de passe, contactez immédiatement le support technique.

❖ Accès aux services et restrictions

Afin de garantir la sécurité du réseau, plusieurs mesures ont été mises en place. Les informations ci-dessous vont permettre d'accéder aux services de manière sécurisée et conformément aux nouvelles politiques.

- **Accès restreint** : L'accès aux services est limité selon vos besoins métiers et les droits d'accès définis par l'entreprise.
- **Authentification forte (MFA)** : Lors de l'accès aux ressources sensibles, vous devrez entrer un code reçu sur votre téléphone ou par email, en plus de votre mot de passe, pour confirmer votre identité
- **Installation de logiciels** : Utilisez le "store interne" pour installer des logiciels approuvés. Pour des demandes spécifiques, contactez le support IT.
- **Sécurité renforcée** : Toute tentative d'accès non autorisé sera automatiquement bloquée et signalée à l'équipe de sécurité.

Ces mesures visent à assurer la sécurité de vos accès et de l'environnement de travail. En cas de doute ou de besoin d'assistance, n'hésitez pas à contacter le support technique.

❖ Accès aux services web via Proxy

Le réseau utilise désormais un proxy pour filtrer et sécuriser l'accès aux sites web. Le proxy permet de contrôler les flux sortants et d'empêcher l'accès à des sites malveillants.

- Seuls les sites web approuvés par l'entreprise sont accessibles. Si vous avez besoin d'accéder à un site particulier, une demande devra être faite au support IT pour l'ajout de ce site à la liste autorisée.
- Le proxy permet de garder une trace des connexions effectuées, garantissant ainsi un suivi des accès aux ressources en ligne.

Ces mesures visent à renforcer la sécurité et à garantir l'intégrité des flux d'information. Pour toute question ou besoin d'accès spécifique, contactez le support.

❖ Connexion à distance via VPN

Afin de sécuriser les connexions à distance, un VPN (Virtual Private Network) a été mis en place. Cela permet de garantir que vos échanges avec le réseau interne sont protégés par un chiffrement de bout en bout, réduisant ainsi les risques d'interception des données sensibles.

- L'accès au réseau interne est autorisé uniquement via un VPN sécurisé.
- Étapes pour vous connecter au VPN :
- Téléchargez et installez le client VPN via le store interne
 - Ouvrez le client VPN et entrez vos identifiants
 - Une fois connecté, vous accédez au réseau comme si vous étiez physiquement présent dans l'entreprise.
- Se connecter depuis un appareil professionnel et éviter l'usage de dispositifs personnels non sécurisés
 - Éviter d'accéder aux ressources de l'entreprise depuis un Wi-Fi public non sécurisé.
 - Se déconnecter du VPN une fois la session terminée.

Lorsque vous travaillez à distance, vous devrez vous connecter via le VPN pour accéder aux services internes, y compris les partages de fichiers et les applications. Cette étape supplémentaire assure une connexion sécurisée.

3.2 Procédure administrateurs :

En tant qu'administrateur du réseau, vous êtes responsable de la gestion et de la sécurité des services et des utilisateurs. Les modifications effectuées sur l'infrastructure nécessitent de nouvelles procédures pour garantir la conformité, la sécurité et la gestion des accès.

❖ Sécurité des mots de passe

Un mot de passe sécurisé est la première barrière de protection contre les intrusions. Les règles suivantes doivent être respectées :

- Utiliser un mot de passe d'au moins 12 caractères, combinant majuscules, minuscules, chiffres et caractères spéciaux.
- Ne jamais utiliser le même mot de passe pour plusieurs services.
- Modifier son mot de passe tous les 90 jours et en cas de suspicion de compromission.

❖ Comptes administrateurs et sécurisation des accès privilégiés

Dans le cadre de la sécurité du réseau, le principe du moindre privilège est appliqué pour les administrateurs, garantissant qu'ils disposent uniquement des droits nécessaires à leurs tâches.

- Chaque administrateur utilise un compte personnel limité pour les activités quotidiennes et un compte administratif dédié pour les actions nécessitant des privilèges élevés.
- L'accès aux ressources critiques est restreint aux administrateurs concernés, et toute élévation de privilèges doit être temporaire et justifiée.
- Les comptes partagés sont interdits pour garantir la traçabilité des actions.

Pour renforcer la sécurité des comptes administrateurs :

- L'accès est protégé par une authentification multi facteur (MFA).

- L'administration des systèmes critiques se fait uniquement depuis un poste sécurisé, isolé du réseau utilisateur.
- Les sessions administratives doivent être fermées après usage et ne jamais rester ouvertes sans surveillance.

❖ Connexion sécurisée aux systèmes administratifs

Pour garantir la sécurité des actions administratives et limiter les risques d'accès non autorisés, il est impératif de respecter les bonnes pratiques suivantes lors des connexions aux serveurs :

- **Connexion via SSH ou RDP** : Les administrateurs doivent impérativement se connecter aux serveurs (notamment les systèmes critiques) en utilisant **SSH** pour les serveurs Linux ou **RDP** pour les serveurs Windows.
- **Poste d'administration dédié** : Toutes les connexions SSH ou RDP doivent être effectuées **uniquement depuis un poste d'administration dédié**. Ce poste doit être sécurisé, avec des accès restreints et une surveillance régulière pour éviter toute compromission.
- **Authentification multifacteur (MFA)** : L'accès aux serveurs via SSH ou RDP doit être sécurisé par une authentification multifacteur (MFA) pour renforcer la sécurité des sessions administratives.
- **Surveillance des connexions** : Les connexions SSH et RDP doivent être journalisées et surveillées en temps réel via le système de gestion des logs (Rsyslog) pour détecter toute tentative d'accès non autorisée ou comportement suspect
- **Session fermée après usage** : Les sessions administratives (SSH/RDP) doivent toujours être fermées immédiatement après utilisation, et ne jamais rester ouvertes sans surveillance.

Cette approche garantit une gestion sécurisée des accès aux ressources critiques tout en maintenant la traçabilité des actions administratives.

❖ Accès distant via VPN sécurisé

Lorsqu'un administrateur doit accéder aux systèmes à distance, il doit suivre les procédures suivantes pour garantir la sécurité des connexions :

- **Connexion via VPN** : L'accès aux systèmes internes se fait uniquement via un VPN sécurisé, assurant la protection des données par un tunnel crypté.
- **Poste d'administration dédié** : Le VPN doit être utilisé depuis un **poste sécurisé** spécifiquement configuré pour les tâches administratives.
- **Authentification multifacteur (MFA)** : Une **MFA** est obligatoire pour toute connexion VPN, ajoutant une couche de sécurité supplémentaire.
- **Accès restreint** : L'accès aux services internes est limité aux tâches nécessaires, et les autres services doivent être restreints.

❖ Journalisation et suivi des événements

La journalisation des actions administratives permet de détecter rapidement les anomalies et d'assurer la sécurité du réseau. Voici les pratiques à suivre :

- Toutes les actions effectuées avec des comptes administrateurs doivent être enregistrées et envoyées vers le serveur de logs centralisé (Rsyslog).
- Les logs sont stockés de manière sécurisée et doivent être conservés conformément aux politiques de l'entreprise.
- Des alertes en temps réel sont configurées sur le serveur de logs pour détecter toute tentative d'accès non autorisée ou comportement suspect.

- Un examen régulier des journaux d'événements sera effectué pour repérer toute compromission éventuelle.

❖ Application des mises à jour et correctifs

Le maintien à jour des systèmes est une mesure essentielle pour réduire les vulnérabilités exploitées par les attaquants, ainsi l'Hyperviseur qui était initialement en version 2016 a été mis à jour pour assurer la sécurité et la compatibilité avec les dernières technologies. De même la VM Windows Server 2012 a été mise à jour pour renforcer sa sécurité et bénéficier des dernières améliorations. Pour ce qui est de la VM Debian 8 (Serveur Applicatif), elle a aussi été mise à jour pour intégrer les derniers patchs de sécurité et améliorer les performances.

- Les mises à jour de sécurité doivent être appliquées dès leur publication, en suivant une procédure de test avant leur déploiement en production.
- Un suivi des correctifs publiés par les éditeurs est nécessaire pour identifier rapidement les failles critiques.
- Les mises à jour des équipements réseau (routeurs, switches, pare-feu) doivent être effectuées selon un planning de maintenance et après validation sur un environnement de test.
- Les services obsolètes ou non sécurisés doivent être désactivés ou remplacés.

❖ Utilisation de WSUS pour les mises à jour Windows

Dès à présent, les mises à jour des systèmes Windows doivent être gérées via **WSUS** (Windows Server Update Services) pour centraliser et contrôler leur déploiement. Voici les étapes à suivre :

- **Accès à WSUS** : Les administrateurs doivent se connecter à l'interface WSUS pour consulter les mises à jour disponibles.
- **Validation des mises à jour** : Avant le déploiement, vérifiez les mises à jour disponibles et testez-les dans un environnement de test pour garantir leur compatibilité.
- **Déploiement contrôlé** : Utilisez WSUS pour déployer les mises à jour sur les systèmes Windows, en vous assurant que les machines reçoivent les mises à jour nécessaires sans perturber les opérations.
- **Suivi et reporting** : WSUS fournit un tableau de bord pour suivre l'état des mises à jour et générer des rapports sur leur application.

Cela permet de centraliser le processus, de réduire les risques d'erreur, et d'assurer une gestion efficace des mises à jour tout en minimisant l'impact sur les systèmes en production.

❖ Sauvegardes et restauration

La gestion des sauvegardes est cruciale pour garantir la disponibilité des données et la récupération en cas de sinistre. Voici les pratiques à suivre pour les sauvegardes :

- **Utilisation de rsync pour les sauvegardes** : Les sauvegardes sont effectuées via l'outil **rsync**, qui permet de synchroniser efficacement les fichiers entre les systèmes source et de stockage dédié.
- **Stockage dédié** : Les sauvegardes sont stockées sur un espace dédié et sécurisé, afin d'éviter toute perte de données en cas de panne du système principal.
- **Planification des sauvegardes** : Les sauvegardes sont planifiées pour s'exécuter de manière régulière (quotidienne, hebdomadaire, selon la criticité des données). La planification doit être automatisée via des scripts ou des outils de gestion des tâches, pour garantir qu'aucune sauvegarde ne soit oubliée.

- **Tests de restauration réguliers** : Des tests de restauration doivent être effectués périodiquement pour vérifier la validité des sauvegardes et s'assurer que les processus de récupération fonctionnent correctement en cas de besoin.

Ces étapes garantissent non seulement la sécurité des données, mais aussi une capacité de récupération rapide et fiable en cas de problème.

4. Bonnes pratiques :

Pour renforcer la sécurité du système d'information, tous les utilisateurs (y compris les administrateurs) doivent adopter les bonnes pratiques suivantes :

❖ Sensibilisation au phishing et aux cybermenaces

Les cyberattaques ciblent souvent les utilisateurs pour compromettre le réseau. Pour limiter ces risques :

- **Vérifiez l'expéditeur des emails** et évitez de cliquer sur des liens ou pièces jointes suspects.
- **Ne communiquez jamais** d'informations sensibles (identifiants, mots de passe) par email ou téléphone.
- **Soyez vigilant face aux demandes urgentes** ou inhabituelles, notamment celles impliquant des paiements ou des accès sensibles.
- **Signalez immédiatement tout email suspect** ou toute activité inhabituelle au service informatique.

❖ Formation continue et adoption des bonnes pratiques

- **Verrouillez votre session** lorsque vous quittez votre poste de travail.
- **Éviter d'utiliser des périphériques USB inconnus** (risque de malware).
- **Privilégier les connexions filaires au Wi-Fi public** pour les accès sensibles.
- **Effectuer des formations régulières** sur les nouvelles menaces et les réflexes à adopter.

5. Conclusion :

La mise en place de ces mesures renforce la sécurité et la fiabilité du système d'information en garantissant un accès contrôlé, une gestion rigoureuse des privilèges et une protection proactive contre les menaces. L'application stricte des bonnes pratiques par tous les utilisateurs et administrateurs est essentielle pour prévenir les risques et assurer la continuité des services.

Il est donc primordial de respecter ces directives et de signaler toute anomalie ou tentative de compromission au service informatique. La cybersécurité est l'affaire de tous : une vigilance permanente et une sensibilisation continue permettront de garantir un environnement numérique plus sûr et performant.